

ATIVIDADE 11

Roteiro de Apresentação — Análise Estática e Refatoração

Aluno

- Beto da Silva — RA 12525178737

1. Contexto

ProcessadorPagamento.java — código com bugs proposital pra prática de análise estática com Checkstyle, SpotBugs e Semgrep no VS Code.

2. Os 8 problemas encontrados

ID	Ferramenta	Linha	Descrição	Tipo	Severidade
1	Checkstyle	3	Import wildcard java.util.* reduz clareza e controle de dependências	Estilo/Manutenibilidade	Baixa
2	Checkstyle	5	Classe sem documentação Javadoc	Estilo/Manutenibilidade	Baixa
3	Checkstyle	7	Método processar sem documentação Javadoc	Estilo/Manutenibilidade	Baixa
4	Checkstyle	40	validarSenha sem documentação Javadoc	Estilo/Manutenibilidade	Baixa
5	Checkstyle	49	calcularDesconto sem documentação Javadoc	Estilo/Manutenibilidade	Baixa
6	SpotBugs	42	Comparação de senha String com == verifica identidade, causando autenticação incorreta	Bug	Alta

7	Semgrep	41	Senha fixa hardcoded em senhaCorreta	Segurança	Alta
8	Semgrep	42	Comparação de String usando ==	Bug	Alta

O SpotBugs registrou o bug do == uma única vez; o Semgrep registrou a senha fixa e o == separadamente, para que cada correção fique rastreável.

3. Refatoração aplicada

- Early Return / Extract Method — validações e cálculo de taxa extraídos em métodos próprios
- Constantes nomeadas no lugar dos números mágicos
- Javadoc adicionado na classe e nos métodos públicos
- Imports explícitos no lugar do wildcard
- Correção de segurança: validação de senha por PBKDF2-HMAC-SHA256 + salt aleatório em Base64, 600.000 iterações, 256 bits, comparação resistente a timing attack, seguindo a OWASP Password Storage Cheat Sheet

4. Resultado (depois da refatoração)

Métrica	Antes	Depois	Melhoria
Total de problemas (Checkstyle, 4 espaços)	5	0	100% menos
Total de problemas (SpotBugs)	1	0	100% menos
Total de problemas (Semgrep)	2	0	100% menos
Complexidade ciclomática máxima	9	6	33% menos
Profundidade máxima de if aninhado	3	0	100% menos
Números mágicos (Checkstyle dedicado)	9	0	100% menos

5. Validação funcional

230 verificações automatizadas comparando o comportamento do código refatorado com o original: 168 combinações de pagamento, 40 combinações de desconto, limites de cartão, quatro entradas de senha e cinco configurações inválidas. Todas aprovadas — a refatoração não alterou o comportamento esperado do sistema.

6. Limitações documentadas (transparência)

- A senha de demonstração continua fixa no código (admin123) — mas a validação já está pronta pra receber hash e salt fornecidos externamente por um serviço de credenciais real
- A exigência de cartão com 16 caracteres foi mantida até para PIX, só para preservar a comparação comportamento-a-comportamento com a suíte de 230 testes (registrado no Javadoc como limitação didática)

7. Ferramentas e versões usadas

Checkstyle 9.3 (mesmo jar da extensão VS Code), SpotBugs 4.10.4, Semgrep 1.179.0, com duas regras locais incluídas no projeto.